

0. Introducción

Grupo e integrantes:

Grupo 3

Daniel

José

Abel

Manuel Jesús Fernández Torrejón

Presentación del ejercicio:

Este documento desarrolla el Análisis de Riesgos previo a la elaboración del Plan Director de Seguridad (PDS) de una empresa de asesoría a autónomos y pymes. El objetivo es identificar los activos críticos, evaluar los riesgos asociados y definir medidas preventivas para garantizar la confidencialidad, integridad y disponibilidad de la información.

Contexto de la empresa:

- Empresa de asesoría a pymes y autónomos.
- 150 empleados distribuidos en dos sedes.
- Actividad basada en la gestión de datos de clientes, documentación contable y servicios digitales.
- Dispone de servidores locales y servicios en la nube.
- Ha sufrido recientemente un incidente de malware.
- Usa CRM y ERP para la gestión interna.
- Dispone de una web con tienda online gestionada externamente.
- Utiliza redes sociales para promoción y comunicación.
- Seguridad física externalizada.

Objetivo de la empresa:

Mejorar su posición en el mercado a través de la transformación digital y el fortalecimiento de la confianza de los clientes mediante una adecuada protección de la información.

Departamentos:

Facturación y ventas, compras, comunicación y RRSS, TIC, RRHH, Delivery, mantenimiento, legal y consejo de administración.

Instalaciones/Sedes:

- Sede principal: edificio completo.
- Sede secundaria: planta compartida en edificio con otras empresas.

Servicios TIC:

- Correo electrónico corporativo.
- Servidores internos y almacenamiento en la nube.
- Página web y tienda online.
- Dispositivos móviles, PCs, red WiFi.
- Antivirus, firewall, copias de seguridad.

Calendario de realización y seguimiento:

- Análisis inicial: 2 semanas.
- Validación por dirección: 1 semana.
- Revisión y actualización anual o tras incidentes graves.

1. Alcance del análisis

El análisis se centra en los activos tecnológicos y de información más críticos para la operación del negocio:

- Servidores (correo, archivos, aplicaciones)
- Datos de clientes y proveedores
- Puestos de trabajo y dispositivos móviles
- Web y servicios en la nube

- Red corporativa interna
- Sistemas de copias de seguridad

El objetivo es establecer un marco de seguridad que garantice los principios de la confidencialidad, integridad y disponibilidad (CIA) de la información y los servicios.

2. Identificación de los activos

Tipo de activo	Descripción	Valor
Datos personales	Información de clientes y proveedores	Muy alto
Servidor de archivos	Documentos internos, contabilidad, informes	Alto
Servidor de correo	Comunicación interna y con clientes	Alto
Equipos de usuario	PCs y portátiles de empleados	Medio
Red corporativa	Routers, switches, WiFi, cableado	Alto
Sistema de copias de seguridad	Soporte de recuperación ante incidentes	Muy alto
Aplicaciones (CRM/ERP)	Procesos de gestión de clientes y operaciones	Muy alto

Página web / tienda online	Imagen pública y canal de contacto	Alto
Servicios en la nube	Almacenamiento compartido de documentos	Alto

3. Amenazas que pueden afectar a los activos

Activo	Amenaza	Descripción
Datos personales	Fuga de información	Acceso no autorizado o robo de datos
Servidor de archivos	Ransomware	Cifrado de datos críticos
Red corporativa	Intrusión / hacking	Acceso remoto no autorizado
Equipos de usuario	Malware, phishing	Infección por descargas o correos falsos
Copias de seguridad	Pérdida o corrupción	Fallos de soporte o manipulación humana
Aplicaciones (CRM/ERP)	Fallo de autenticación	Acceso indebido por usuarios no autorizados
Web/Tienda online	Ataque DDoS, inyección SQL	Interrupción del servicio o robo de datos

Servicios en la nube

Falla del proveedor o fuga

Pérdida de acceso o
exposición pública

4. Identificar vulnerabilidades y salvaguardas

4.1 Salvaguardas existentes

Tipo	Medida actual	Observaciones
Técnica	Firewall y antivirus	Configurados por terceros; sin revisión de dirección
Organizativa	Cumplimiento RGPD	Correcto y documentado
Técnica	Copias de seguridad locales	No externalizadas; riesgo físico
Técnica	Segmentación de red	Solo conocida por el admin de red
Física	Seguridad subcontratada	Adecuada, pero limitada a accesos físicos
Legal	Consultoría RGPD aprobada	Cumplimiento vigente

4.2 Vulnerabilidades

Tipo	Descripción
Falta de políticas de seguridad formalizadas	No existen procedimientos aprobados
Dependencia de terceros sin supervisión	Web, antivirus, seguridad física
Falta de formación en ciberseguridad del personal	Posible origen de infecciones por phishing
Copias locales no cifradas ni redundantes	Riesgo en caso de siniestro físico
Control limitado sobre la web externa	Posibles brechas no detectadas
Carencia de gestión de accesos centralizada	Contraseñas débiles o compartidas

5. Evaluación y cálculo del riesgo

Puedes usar una escala de 1 a 5 para probabilidad (P) e impacto (I), y calcular el riesgo ($R = P \times I$).

Activo	Amenaza	Prob.	Impacto	Riesgo	Nivel
Datos personales	Fuga de información	4	5	20	Muy alto
Servidor de archivos	Ransomware	4	5	20	Muy alto

Red corporativa	Intrusión	3	4	12	Alto
Copias de seguridad	Corrupción	3	4	12	Alto
Web/Tienda online	Ataque externo	3	3	9	Medio
Equipos de usuario	Malware	4	3	12	Alto
CRM/ERP	Fallo autenticación	2	4	8	Medio
Servicios nube	Pérdida de acceso	2	3	6	Medio

Umbral de aceptación del riesgo:

Se considera aceptable un riesgo ≤ 6 . Todo riesgo superior requerirá medidas adicionales.

6. Medidas complementarias

Riesgo	Medidas propuestas	Riesgo residual
Fuga de información	Implantar políticas de seguridad y formación al personal	Medio

Ransomware	Copias cifradas automáticas en la nube y pruebas de restauración	Bajo
Intrusión en red	Auditoría de seguridad anual, actualización de firmware	Bajo
Malware en equipos	Sistema EDR centralizado y formación en phishing	Bajo
Web externa	Revisión de seguridad del hosting y certificado SSL	Medio
Copias corruptas	Sistema redundante de backups externos	Bajo
Pérdida de acceso nube	Contrato SLA con proveedor, verificación doble factor	Bajo

7. Conclusión

El análisis revela que la empresa tiene una base tecnológica funcional pero insuficientemente controlada, con dependencia de proveedores externos y falta de políticas formales.

Las mayores amenazas se concentran en los datos personales y servidores internos, especialmente ante ataques de malware o ransomware.

La prioridad inmediata debe ser implantar un Plan Director de Seguridad que:

- Formalice políticas internas (uso de contraseñas, dispositivos, redes).
- Aumente la concienciación del personal.
- Estructure la gestión de incidentes y copias de seguridad seguras.

- Refuerce la gobernanza de proveedores externos (web, antivirus, seguridad).

8. Bibliografía / Webgrafía

- [Guía de gestión de riesgos - INCIBE](#)
- [Revilofe - Análisis de riesgos](#)
- ISO/IEC 27005:2018 - Information security risk management
- ENISA - Risk Management Guidelines for SMEs